KAPASA MAKASA UNIVERSITY

SCHOOL OF APPLIED SCIENCES AND OPEN LEARNING

DEPARTMENT OF INFORMATION AND COMMUNICATIONS TECHNOLOGY

BACHELOR OF SCIENCE IN CYBERSECURITY

COURSE CODE: CYS 453

COURSE TITLE: MOBILE DEVICE SECURITY AND FORENSICS

2026 EARLY SESSIONAL EXAMINATION

DATE: 10th November 2026 TIME: 14:00-17:00

INSTRUCTIONS

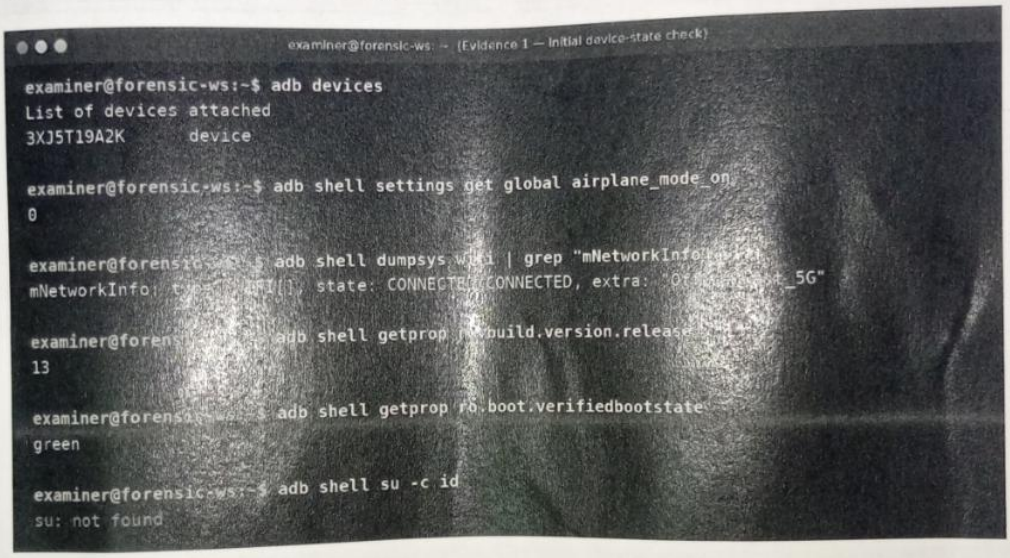
1. Write your **Student Identification Number** on the Answer Booklet provided
2. Question 1 in **SECTION A** is compulsory
3. Choose any FOUR (4) questions in **SECTION B**
4. Each Question carries 20 marks
5. Always begin answering a new question on a fresh page

SECTION A: COMPULSORY [20 Marks]

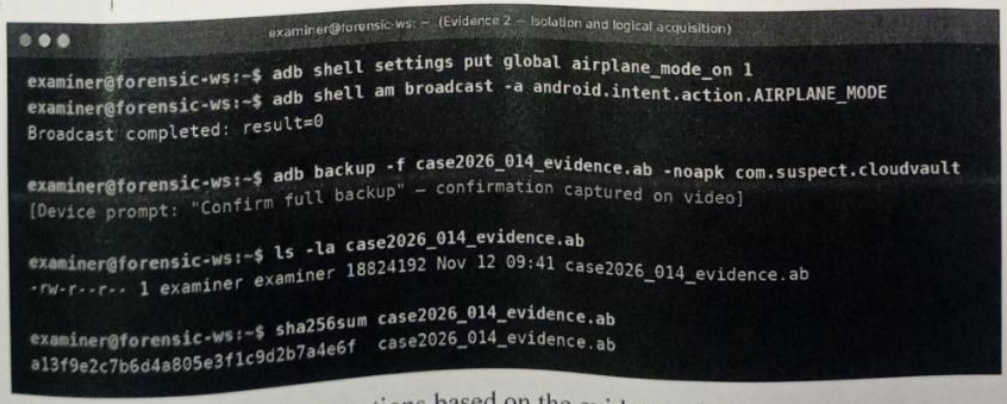
Question 1

Zesa Microfinance PLC has voluntarily surrendered a company-issued Android smartphone belonging to a departing employee, following an internal report of suspected data exfiltration. The device was powered on and unlocked at the time of handover. Before beginning acquisition, the digital forensic examiner records the device's current state, then proceeds to isolate and acquire it. The examiner's terminal session is captured in the evidence below.

Evidence 1: Initial device-state check



Evidence 2: Isolation and logical acquisition



Now answer the following questions based on the evidence above.

(a) Define the following terms as used in mobile forensics:

(i) Logical acquisition **[2marks]**

(ii) Chain of custody **[2 marks]**

(b) Differentiate between the purpose of the commands run in Evidence 1 and those run in Evidence 2. In your answer, highlight two differences with respect to their objective and the stage of the forensic process each belongs to. **[6 marks]**

(c) Analyse the information disclosed in Evidence 1 and Evidence 2 and explain three specific details from the screenshots that a defence lawyer could challenge regarding the lawfulness or integrity of this acquisition. **[6 marks]**

(d) As the lead forensic examiner, evaluate the overall approach taken and recommend four best-practice safeguards that would make this acquisition more defensible in court. **[4 marks]**

Question 2

Read the following case study carefully and answer the questions that follow.

Kalaba was a senior client-relations officer at Mfumu Microfinance Ltd. Two days after tendering her resignation, IT Security received an alert that her company-issued Android phone had gone offline. When the device was recovered from her desk during handover, it was found powered off. Before any forensic examiner was involved, the receiving officer powered the device back on to check for damage; the phone briefly reconnected to the office Wi-Fi and displayed a "Find My Device: Erase this device?" prompt, which the officer dismissed without recording it.

Subsequent review by IT Security confirmed the following:

i. Find My Device (Android's built-in remote-wipe feature) was enabled on the device.

ii. The device was not enrolled in any Mobile Device Management (MDM) solution.

iii. A personal Google account had been added to the device six days before Kalaba's resignation letter was submitted.

iv. Application usage logs show the customer-relations app was used to export a client contact list to a personal cloud-storage app forty minutes before the resignation email was sent.

The organisation has engaged your forensic consultancy to investigate the incident and advise on its security posture.

(a) As the lead forensic examiner, analyse the evidence presented and identify the most likely threat or incident affecting the organisation. Justify your conclusion using details from the case study. **[8 marks]**

(b) Critically evaluate the receiving officer's handling of the device before forensic involvement, explaining what forensic risk(s) this introduced. **[6 marks]**

(c) IT Security argues that because Find My Device is a built-in Android security feature, its presence proves the device was adequately protected against data misuse. Assess whether this conclusion is justified. **[3 marks]**

(d) Recommend three (3) additional organisational or technical controls that would improve the company's ability to detect and forensically investigate similar incidents in future. **[3 marks]**

Question 3

A messaging application's SQLite database, chats.db, was extracted from a suspect's Android device during a fraud investigation. The suspect claims all incriminating messages were deleted before the device was seized. The examiner's workstation session, captured while examining the database, is shown in Figure 3.0 below.

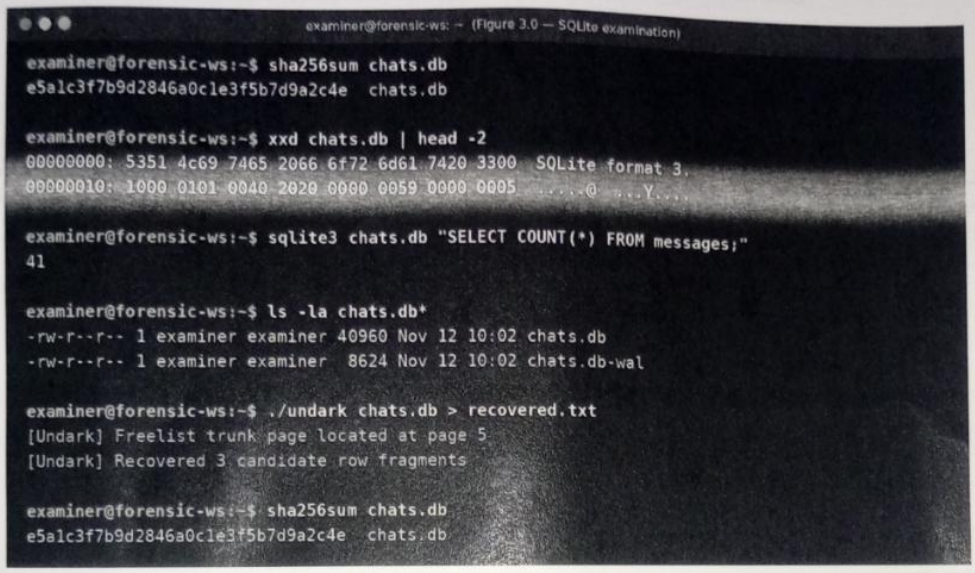


Figure 3.0

(a) Using Figure 3.0, identify four (4) pieces of information the examiner has established about the chats.db database and explain why each is forensically useful. **[8 marks]**

(b) Referring to the internal structure and behaviour of SQLite databases, **determine** the most likely explanation for each of the following observations, with a reason:

(i) The sqlite3 query returns only 41 messages, none of which match the deleted content described by the suspect. **[2 marks]**

(ii) Undark is able to recover candidate row fragments despite the deleted rows being absent from a normal query. **[2 marks]**

(iii) A chats.db-wal file exists alongside the main database file. **[2 marks]**

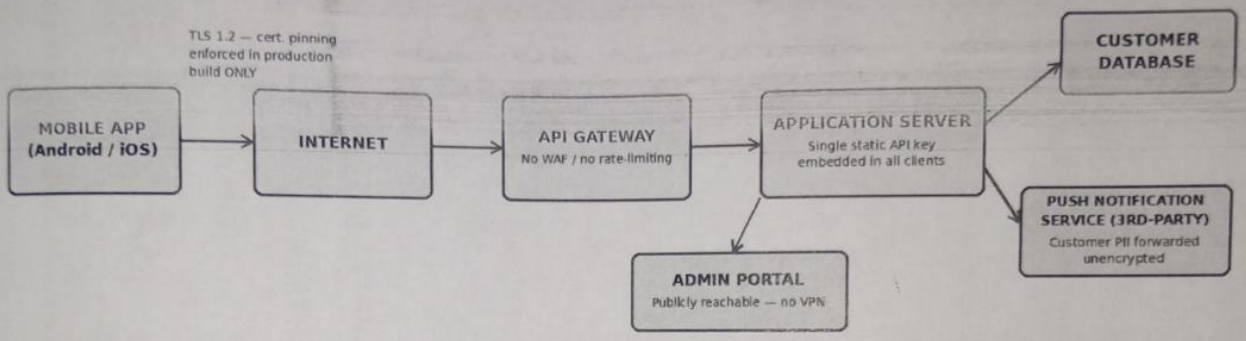
(iv) The SHA-256 hash of chats.db is identical before and after the Undark scan. **[2marks]**

(c) Recommend two (2) actions the examiner should take to preserve the admissibility of the recovered evidence before it is presented in court. **[4 marks]**

Question 4

ZamPay Ltd. has engaged your firm to conduct a mobile application penetration test of its Android banking application. During reconnaissance, your team maps the application's backend architecture, shown in Figure 4.0 below.

ZAMPAY MOBILE BANKING — BACKEND NETWORK TOPOLOGY



Reconnaissance notes:

- Certificate pinning verified present in the production build, absent from the staging build used for this test.
- The Admin Portal is reachable directly from the Internet without VPN or IP allow-listing.
- A single static API key is compiled into every client installation (see Evidence 1, Q7).
- The push-notification integration forwards customer PII to a third party without field-level encryption.
- No Web Application Firewall or rate-limiting sits between the Internet and the API Gateway.

Figure 4.0

(a) Using Figure 4.0, identify and explain four (4) security weaknesses in ZamPay's backend architecture. **[4 marks]**

(b) For each weakness identified in (a):

(i) Explain how an attacker could exploit it during a mobile penetration test. **[4 marks]**

(ii) Discuss the potential impact on the confidentiality, integrity, or availability of customer data. **[4 marks]**

(c) Using Figure 4.0, identify one asset that is most critical to protect and explain why it is a high-value target for attackers. **[4 marks]**

(d) As the lead penetration tester, **recommend four (4)** security technologies that should be added to this architecture. For each technology, indicate its most appropriate location and the risk it mitigates. **[4 marks]**

Question 5

During the same engagement, the examiner reviews the Developer options configured on the device recovered in Question 1, shown in Figure 5.0 below.

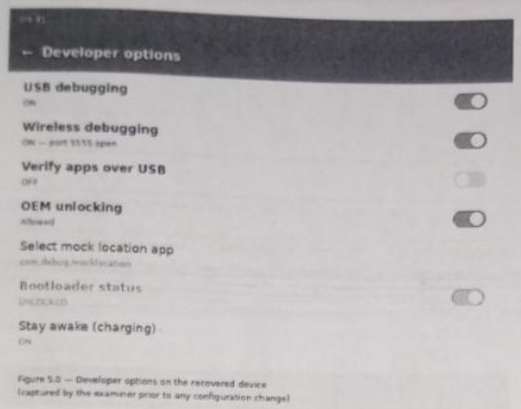


Figure 5.0

(a) Using Figure 5.0, identify four (4) weaknesses in the device's current security configuration, and for each weakness, explain how it could be exploited during a mobile forensic or penetration testing exercise. **[8 marks]**

(b) Recommend an improved configuration for the device by copying and completing the table below. **[8 marks]**

Setting	Recommended Value	Justification
USB debugging		
Wireless debugging		
OEM unlocking		
Bootloader status		

(c) Evaluate how implementing your recommended configuration would reduce the risk of unauthorised data extraction via ADB. **[4 marks]**

Question 6

As part of a security assessment of a banking application, com.zambank.mobile, your team uses the Drozer framework to assess its attack surface. The console session is shown in Figure 6.0 below.

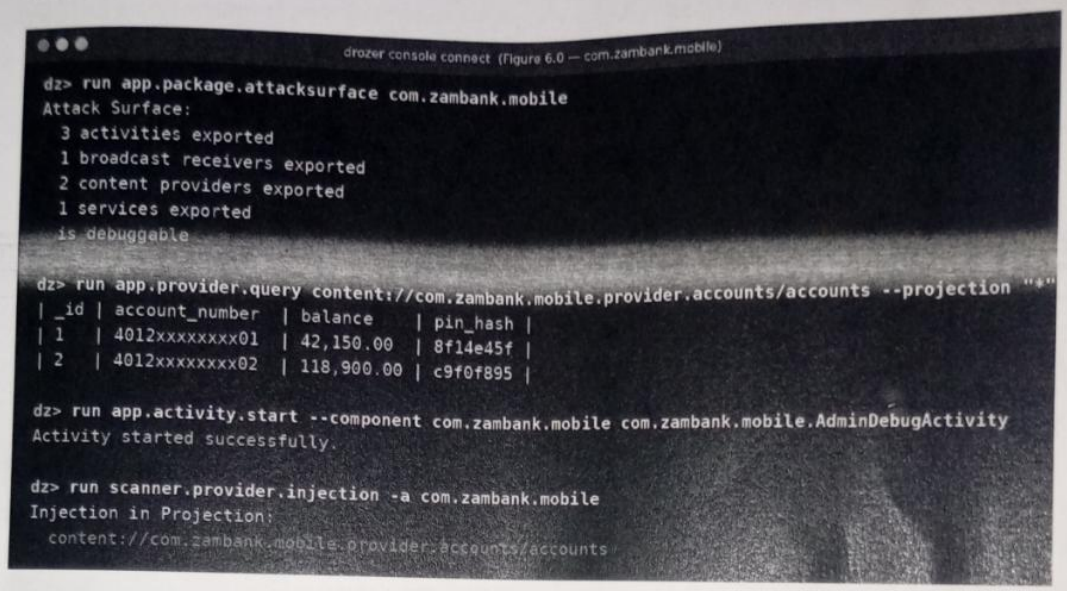


Figure 6.0

(a) Using Figure 6.0, identify four (4) pieces of information the tester has discovered about com.zambank.mobile and explain why each is significant during an Android security assessment. **[8 marks]**

(b) Referring to the Android application component security model, determine the most likely root cause for each of the following observations, with a reason:

(i) The AdminDebugActivity could be launched directly without any authentication prompt. **[2 marks]**

(ii) The accounts content provider returned customer account data without requiring a permission. **[2marks]**

(iii) The scanner.provider.injection module reported the accounts provider as vulnerable to injection in its projection parameter. **[2 marks]**

(iv) The attack surface summary flags the application as "is debuggable". **[2 marks]**

(c) The lead tester recommends that the application should not export components unless explicitly required for inter-application functionality. Using the results in Figure 6.0, recommend two (2) actions the development team should implement before the next assessment. **[4 marks]**

Question 7

Study ZamPay Ltd.'s mobile application security assessment report below and answer the questions that follow.

ZAMPAY LTD.

MOBILE APPLICATION SECURITY ASSESSMENT REPORT (EXTRACT)

Confidential — For Internal Use Only

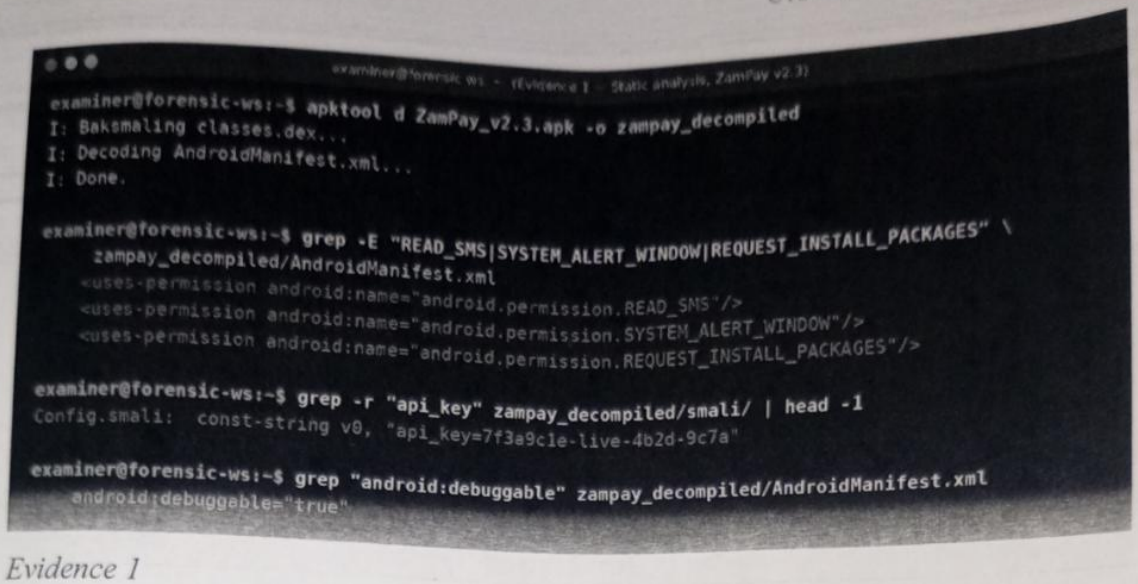
Assessment Information	
Assessment Type	Mobile Application Security Assessment (Static and Dynamic)
Target	ZamPay Mobile Banking Application (Android), v2.3
Assessment Date	3rd November 2026
Conducted By	XYZ Cybersecurity Consultants
Lead Tester	Mr. Try Yakulaba

1.0 Mobile Application Security Findings

1.1 Executive Summary

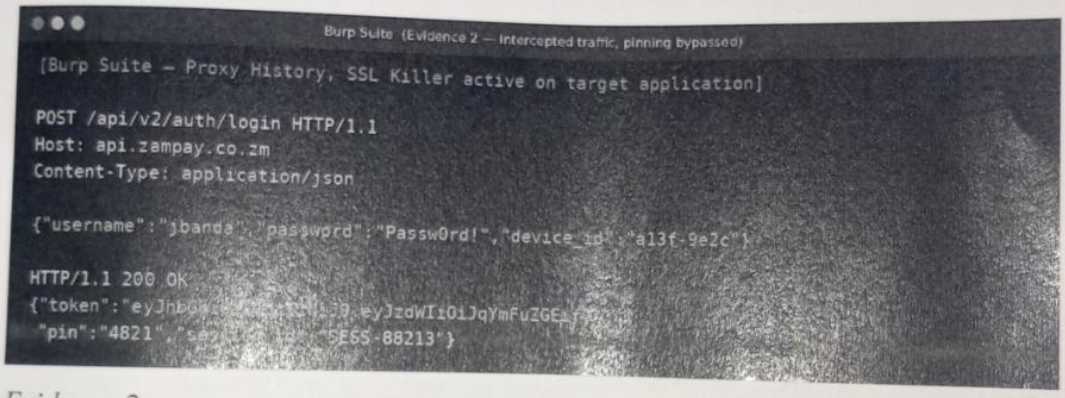
During an authorised mobile application security assessment, the assessment team performed static analysis of the decompiled application package and dynamic analysis of live network traffic following certificate-pinning bypass. Evidence collected during the assessment is presented below.

Evidence 1 — Static Analysis



Evidence 1

Evidence 2 — Intercepted Application Traffic



Evidence 2

1.2 Tester's Findings

ID	Finding	Risk
F-01	SSL certificate pinning bypassed using an Xposed/LSPosed SSL Killer module; full traffic interception achieved	Critical
F-02	Authentication PIN transmitted in plaintext within the login response body	Critical
F-03	Hardcoded live API key found in decompiled smali code (Config.smali)	High
F-04	Application manifest declares android:debuggable="true" in the release build	High

ID	Finding	Risk
F-05	Dangerous permissions (READ_SMS, SYSTEM_ALERT_WINDOW, REQUEST_INSTALL_PACKAGES) requested without clear functional justification	Medium
F-06	Exported content provider found vulnerable to SQL injection via the projection parameter (see Figure 6.0)	Critical

1.3 Risk Rating

Critical	High	Medium	Low
3	2	1	0

(a) Identify four (4) security vulnerabilities evident from the report and explain how each could be exploited by an attacker. **[8 marks]**

(b) Assess the effectiveness of ZamPay's current application security controls based on the evidence presented in the report. **[6 marks]**

(c) Recommend three (3) additional security controls that should be implemented to improve the mobile application's security posture. Justify each recommendation. **[6 marks]**